

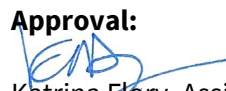


DAS Policy

Risk Assessment

No:
2100-08

Effective:
March 5, 2024

Approval:

Katrina Flory, Assistant Director/State CIO

I. Purpose

This policy provides **Risk Assessment** requirements for Ohio Department of Administrative Services (**DAS**)-managed system assets. The requirements address preparing for, conducting, communicating and maintaining a Risk Assessment. The first occurrence of a defined term in the policy is in bold, italic type, and is hyperlinked to the definition in Section IV.

II. Scope

The scope of this policy includes any DAS-Managed System Assets.

This policy also applies to DAS **Data Owners** and **Service Owners**.

III. Policy

Data Owners and Service Owners, in coordination with the DAS Office of Information Security and Privacy (OISP), shall complete Risk Assessments on all existing DAS-Managed System Assets containing **Sensitive IT System Assets** and/or **Business Critical IT System Assets**. In addition, Risk Assessments are required for any in-process or planned DAS-Managed System Asset development initiatives or procurements. Data owners and Service Owners shall also conduct Risk Assessments on any existing DAS-Managed System Assets, which if compromised or harmed, could potentially have a negative impact on the **Confidentiality, Integrity or Availability** of information.

- A. **Risk Assessment Methodology:** The National Institute of Standards & Technology (NIST) Special Publication (SP) 800-30, "Guide for Conducting Risk Assessments," shall be used to assess **Risk** for DAS-Managed System Assets. The NIST SP 800-30, "Risk Assessment Process,"

illustrates the four core steps of the Risk Assessment methodology¹. These steps shall be followed when conducting Risk Assessments on DAS-Managed System Assets. (Please refer to Figure 1 below for additional details.)

1. Step 1: Prepare for Assessment: Identify the purpose of the Risk Assessment in terms of the information that the assessment is intended to produce and the decisions the assessment is intended to support.

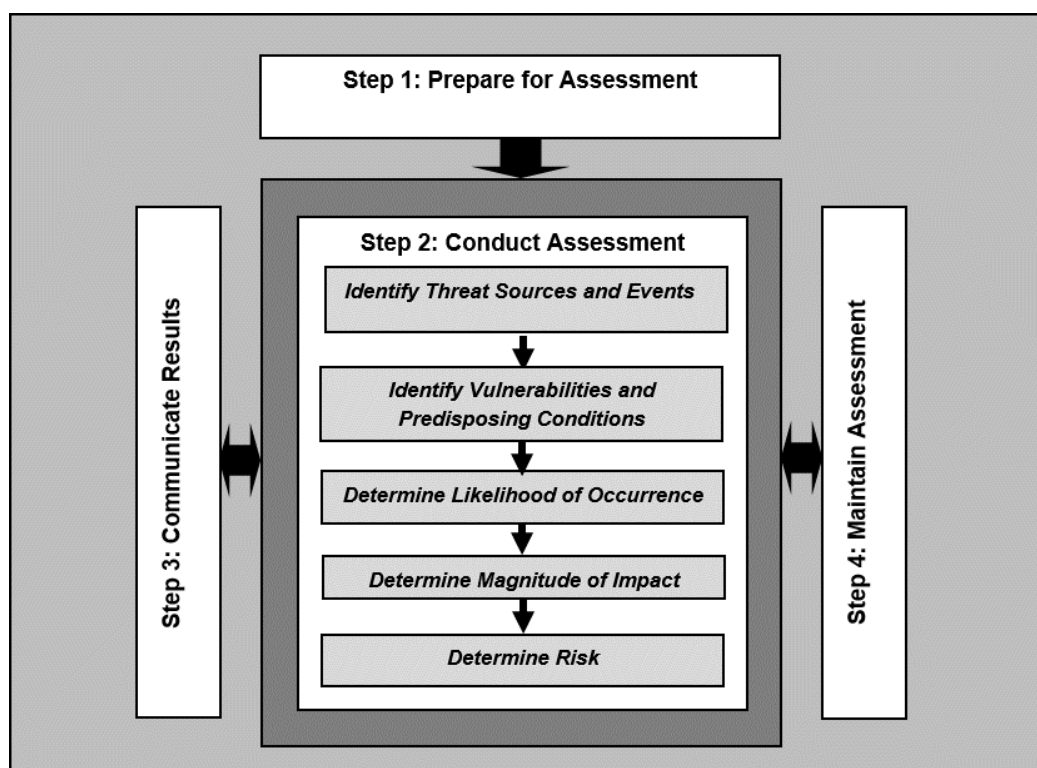


Figure 1: NIST SP 800-30 Risk Assessment Process²

- a) Identify the scope of the effort, which includes time frame, organizational applicability, and the IT systems, resources and information that will be included in the Risk Assessment.
- b) Define the assumptions and constraints associated with a given Risk Assessment (e.g., assumptions made regarding **Threat Sources**, vulnerabilities, likelihood, impacts, risk tolerance, approach).

¹ "NIST Special Publication 800-30 Revision 1, Guide for Conducting Risk Assessments." National Institute of Standards and Technology (NIST) September 2012. <<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf>>.

² *Ibid.*

- c) Identify information sources for the **Threat, Vulnerability** and impact information.
 - d) Determine the Risk model and analytic approach that will be used for the Risk Assessment.
2. Step 2: Conduct Assessment: The objective of this step is to produce a list of information security Risks that can be prioritized by Risk level and used to make informed Risk response decisions.
- a) Identify the **Threat Events** of concern;
 - b) Identify and characterize the most likely Threat Sources for the identified Threat Events, including capability, intent, and targeting characteristics for **Adversarial Threats** and the range of effects of **Non-Adversarial Threats**;
 - c) Identify and document system vulnerabilities that could be exploited;
 - d) Analyze **Security Controls** that are already in place or are planned for implementation that minimize or eliminate the likelihood of a compromise occurring;
 - e) Determine the likelihood of potential vulnerabilities being exercised by a Threat Source;
 - f) Determine the impact associated with the compromise of DAS-Managed System Assets;
 - (1) As part of the assessment process, data classification labels assigned in accordance with Ohio Administrative Policy IT-13, "Data Classification," shall be closely reviewed to help determine the overall impact of a compromise of DAS-Managed System Assets.
 - g) Determine the level of Risk using a rating methodology that is in alignment with NIST SP 800-30;
 - h) Identify technical, operational and management controls that can mitigate or eliminate the identified Risks; and
 - i) Document Risk Assessment results and control recommendations. Control recommendations shall be based upon Risk Assessment results and shall align with NIST SP 800-53, "Security and Privacy Controls for Federal Information Systems and Organizations," (Revision 4) as required in Ohio IT Standard ITS-SEC-02, "Enterprise Security Controls Framework." The selection of individual controls shall be based upon **System Classification** and an overall understanding of Risks posed to DAS-Managed System Assets.
3. Step 3: Communicate and Share Risk Assessment Results: Communicate Risk Assessment results to organizational decision makers to support Risk responses. In addition, share the results of the Risk Assessment with appropriate organizational personnel.
4. Step 4: Maintain Assessment: Conduct ongoing monitoring of the Risk factors that could impact the Risk to organizational operations and assets, individuals, or other organizations. Also, update existing Risk Assessments

using the results from ongoing monitoring of Risk factors (refer to section C. for additional requirements regarding Risk Assessment updates).

- B. **Risk Assessment Report:** The Risk Assessment results shall be documented in a Risk Assessment report and maintained by DAS OISP. The Risk Assessment report shall document the appropriate actions for managing identified Risks. At a minimum, the following elements shall be included:
1. Treatment Action Items: This is a list of suggested next steps and/or possible Security Controls that will help to lower the level of Risk to DAS-Managed System Assets.
 2. Due Dates: The due date shall identify when action items are to be completed or Security Controls implemented.
 3. Accountability: The report shall identify a person responsible for ensuring that a treatment action item and/or Security Control is implemented.
- C. **Risk Assessment Updates:** A new Risk Assessment shall be conducted every two years, or as a result of significant changes to a DAS-Managed System Asset's environment or infrastructure or following a significant security incident. A significant change is defined as substantial changes that alter the mission, configuration or basic vulnerabilities of the DAS-Managed System Asset. Changes that may indicate the need for a new Risk Assessment include new or significantly changed:
1. Business Requirements
 2. Hardware
 3. Application Programs
 4. External Users
 5. Telecommunications
 6. Location of the IT System (e.g., a new physical environment or a new organization)
 7. IT System Interfaces

IV. Definitions

- A. Adversarial Threat. Any circumstance or event with the potential to adversely impact organizational operations (including mission, functions, image, or reputation), organizational assets, individuals, other organizations, or the state through an information system via unauthorized access, destruction, disclosure, or modification of information, and/or denial of service, conducted by an individual, group, organization, or government that has the intent to cause harm.³
- B. Availability. Ensuring timely and reliable access to and use of information.⁴

³ "NIST Special Publication 800-30 Revision 1, Guide for Conducting Risk Assessments." National Institute of Standards and Technology (NIST) September 2012. <<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf>>.

⁴ "NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems

- C. Business Critical IT System Assets. Assets, systems, or services that are identified as having the greatest potential to impact the achievement of the organizational mission.
- D. Confidentiality. Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.⁵
- E. DAS-Managed System Asset. Information, hardware, software and services required to support state business, and identified during the Risk Assessment process as assets that need to be protected. Primary responsibility for managing these system assets may be assigned to DAS OIT personnel or other outside entities.
- F. Data Classification Labels. Denotes the level of protection based on the Confidentiality and criticality requirements of data in accordance with the agency's Risk Assessment. Data Classification Labels enable policy-based standards for securing and handling data and sharing information among organizations. The terms, "data classification label" and "classification label," are used interchangeably.⁶
- G. Data Owner. In accordance with Ohio Administrative Policy IT-13, "Data Classification", Data Owners shall be responsible for the identification and classification of information, in consultation with legal counsel. Data Owners shall be responsible for the assignment of **Data Classification Labels**, data compilation, data classification coordination and compliance, and data access as detailed in Ohio Administrative Policy IT-13.
- H. Integrity. Guarding against improper information modification or destruction and includes ensuring information non-repudiation and authenticity.⁷
- I. Non-Adversarial Threat. A threat associated with accident or human error, structural failure, or environmental causes⁸ (e.g., information spillage, incorrect privilege settings, fires, floods, natural disasters).⁸
- J. Risk. A measure of the extent to which an entity is threatened by a potential circumstance or event, and typically a function of: (i) the adverse impacts that would arise if the circumstance or event occurs; and (ii) the likelihood of occurrence.⁹
- K. Risk Assessment: The process of identifying, prioritizing, and estimating Risks to organizational operations (including mission, functions, image, and reputation), organizational assets, individuals, other organizations, and the state, resulting from the

and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April, 2013
<<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

⁵ NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April, 2013
<<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

⁶ Stine, Kevin, Rich Kissel, William C. Barker, Jim Fahlsing, Jessica Gulick. "NIST Special Publication 800-60 Revision 1, Volume I: Guide for Mapping Types of Information and Information Systems to Security Categories," U.S. Department of Commerce National Institute of Standards and Technology, August, 2008
<<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-60v1r1.pdf>>.

⁷ *Ibid.*

⁸ "NIST Special Publication 800-30 Revision 1, Guide for Conducting Risk Assessments." National Institute of Standards and Technology (NIST) September 2012. <<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf>>.

⁹ *Ibid.*

operation of an information system.¹⁰

- L. Security Controls. Management, operational and technical policies, procedures and tools required to achieve and maintain the necessary level of assurance of Confidentiality, Integrity and Availability.
- M. Sensitive IT System Assets. Assets and/or systems that contain privileged or proprietary information which, if compromised through alteration, corruption, loss, misuse, or unauthorized disclosure, could cause serious harm to the organization.
- N. Service Owner. A Service Owner is responsible for the delivery (design, performance, integration), continual improvement and management of assigned IT services.
- O. System Classification. Refers to the process of assessing the potential impact to Confidentiality, Integrity and Availability of the evaluated system. NIST SP 800-53 refers to Federal Information Processing Standards (FIPS)-199, which is the federal guideline for assessing and classifying information systems.
- P. Threat. Any circumstance or event with the potential to adversely impact organizational operations (including mission, functions, image, or reputation), organizational assets, individuals, other organizations, or the state through an information system via unauthorized access, destruction, disclosure, or modification of information, and/or denial of service.¹¹
- Q. Threat Event. A Threat Event is an event or situation initiated or caused by a Threat Source that has the potential for causing adverse impact.
- R. Threat Source. The intent and method targeted at the intentional exploitation of a Vulnerability or a situation and method that may accidentally exploit a Vulnerability.¹²
- S. Vulnerability. Weakness in an information system, system security procedures, internal controls, or implementation that could be exploited by a Threat Source.¹³

V. Authority

ORC 125.18

¹⁰ Stine, Kevin, Rich Kissel, William C. Barker, Jim Fahlsing, Jessica Gulick. "NIST Special Publication 800-60 Revision 1, Volume I: Guide for Mapping Types of Information and Information Systems to Security Categories," U.S. Department of Commerce National Institute of Standards and Technology, August, 2008
<<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-60v1r1.pdf>>.

¹¹ "NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April, 2013
<<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

¹² *Ibid.*

¹³ *Ibid.*

VI. Resources

Document Name	Location
NIST Special Publication 800-53, Security and Privacy Controls for Federal Information Systems and Organizations	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf
Federal Information Processing Standards (FIPS)-199	https://csrc.nist.gov/publications/fips
Ohio IT Standard ITS-SEC-02 Security Controls Framework	https://das.ohio.gov/technology-and-strategy/policies
State of Ohio Administrative Policy IT-13 Data Classification	https://das.ohio.gov/technology-and-strategy/policies

VII. Inquiries

Direct inquiries about this policy to:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services
30 East Broad Street, 39th Floor
Columbus, Ohio 43215

614-644-6860 | state.isp@das.ohio.gov

DAS Policies may be found online at
<https://das.ohio.gov/technology-and-strategy/policies>

VIII. Revision History

This policy shall be reviewed no less than every two years and updated as needed.

Date	Description of Change
04/10/2017	Original Policy
8/12/2021	Updated the policy to align with the current DAS OISP Risk Assessment process and DAS policy template. Updated the compliance language to reflect the length of time that the policy has been in place.

Date	Description of Change
03/05/2024	Updated to clarify the applicable NIST SP 800-53 version. Revised the definitions. Updated the policy template. Added a revision history review frequency statement.